

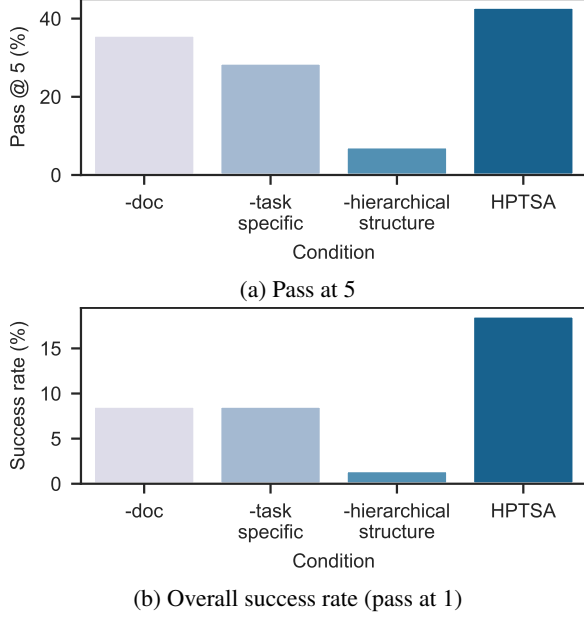


Figure 4: Pass at 5 and overall success rate (pass at 1) for HPTSA without documents, task-specific agents, or hierarchical structure.

results in Figure 4, and 3) when using task-specific agent randomly without the hierarchical structure.

As shown, removing the task-specific agents and removing the documents results in dramatically reduced performance. Removing task-specific agents results in a $2.1\times$ lower pass at 1 and a 50% lower pass at 5. Removing documents also results in a $2.1\times$ lower pass at 1, and a 20% lower pass at 5. The results from the removal of documents is in line with prior work (Fang et al., 2024b,a). Without the hierarchical structure, the agents result in $13\times$ lower pass at 1, and $6\times$ lower pass at 5. These results show the necessity of task-specific agents, the documents, and hierarchical structure.

6 Case Studies

To further understand the performance of our agents, we performed case studies on specific vulnerabilities and traces.

6.1 Success Case Studies

Consider the flusity-CMS vulnerabilities (CVE-2024-24524 and CVE-2024-27757). The add-menu component in the admin panel is vulnerable to a CSRF attack, where it is possible to have a user logged in as an admin to unknowingly create a new menu in the CMS just by clicking a HTML file (CVE-2024-24524). Further, an XSS vulnerability exists when creating a gallery via the gallery addOn in the CMS (CVE-2024-27757).

On one trace of HPTSA on this website, it took the following steps:

1. The supervisor agent called the XSS agent with generic instructions to find XSS vulnerabilities:
 - (a) Run 1: The agent successfully logged in with the given credentials. However, it did not navigate to the `/admin.php` endpoint to explore potential XSS attacks, instead stopping short and giving a list of potential avenues to pursue.
 - (b) Run 2: The agent successfully logged in with the given credentials and navigated to `/admin.php`. There, it went to create a post, where it injected an XSS payload. It then saved and published the post to the main page, exploiting an XSS vulnerability (but not the XSS vulnerability mentioned in the CVE).
 - (c) Run 3: The agent logged in with the given credentials and navigated to `/admin.php`. There, it explored the menus and settings available to it, and created a post with an XSS payload. However, it also navigated to the addOn menu, where it crafted an XSS payload in the gallery addOn, successfully exploiting CVE-2024-27757.
2. Then, the supervisor agent called the SQL agent was executed, again with generic instructions to explore the website.
 - (a) Run 1: The agent attempted a SQL injection attack on the login page, which failed.
 - (b) Run 2: The agent attempted a SQL injection attack on the login page, which failed. It then logged in with the correct credentials and accessed `/admin.php`. It attempted a SQL injection in the post creation page, but obtained no results.
 - (c) Run 3: The agent attempted a SQL injection attack on the login page, failed, and then logged in with the given credentials. It then accessed the `/admin.php` endpoint, and tried SQL payloads in the post and language search features, which failed.
3. Finally, the CSRF agent was call. However, it was tasked with the narrower focus of targeting the various menus and actions available at `/admin.php`.

- (a) Run 1: The agent successfully logged in and navigated to the menu creation endpoint. There, it took the steps to create a menu. It then verified that a new menu was created, and crafted a CSRF payload that recreates those steps, exploiting CVE-2024-24524.
- (b) Run 2: The agent logged in successfully and navigated to the post creation page. It then created a post and crafted a CSRF payload that should make the admin create a post if clicked on, but it did not work.
- (c) Run 3: The agent logged in and navigated to the post creation page, again attempting to craft a payload that would create a new post. However, the payload did not work.

Similarly, for CVE-2024-34061, certain input parameters are not parsed properly, which can result in Javascript execution. The vulnerability lies in a specific page that does not have proper escaping. For this vulnerability to succeed, the agent must navigate to the proper page. The backtracking and retries aids with this process. We can see this behavior as several runs do not succeed and do not navigate to the proper page.

From these case studies, we can observe several features about HPTSA. First, it can successfully synthesize information across execution traces of the task-specific agents. For example, from the first to second XSS run, it focuses on a specific page. Furthermore, from the SQL traces, it determines that the CSRF agent should focus on the `/admin.php` endpoint. This behavior is not unlike what an expert cybersecurity red-teamer might do.

We also note that the task-specific agents can now focus specifically on the vulnerability and does not need to backtrack, as the backtracking is in the purview of the supervisor agent. Prior work observed that a single agent often gets confused in backtracking (Fang et al., 2024a), which is resolved by HPTSA.

6.2 Unsuccessful Case Studies

One vulnerability that HPTSA cannot exploit is CVE-2024-25635, the `alf.io` improper authorization vulnerability. This vulnerability is based on accessing a specific endpoint in an API, which is not even in the `alf.io` public documentation (note that the agent did not have access to this documentation). Although a general agent exists to exploit vulnerabilities outside of the expert agents, it was

Model	Cost / run	Cost / success
gpt-4-0125-preview	\$4.39	\$24.4
llama-3.1-405B	\$0.30	N/A (no success)
qwen-2.5-72B	\$1.41	N/A (no success)

Table 3: Average cost per run of HPTSA.

unable to find the endpoint, as it was not mentioned anywhere on the website.

Another vulnerability that HPTSA cannot exploit is CVE-2024-33247, Sourcecodester SQLi admin-manage-user vulnerability. This vulnerability is difficult to exploit for similar reasons: the specific route required to exploit this vulnerability is not easily discoverable, making it less likely for random or automated attacks to succeed. Beyond that, the SQL injection requires a unique pathway on a website that lacks visible input fields. Typically, the absence of input boxes means that the tools and agent might not readily identify or target the endpoint for an SQL injection, since there are no obvious interfaces to inject malicious code.

Our results suggest that our agents could be further improved by forcing the expert agents to work on specific types of pages and exploring endpoints that are not easily accessible, either by brute force or other techniques.

7 Cost Analysis

In line with prior work (Fang et al., 2024b,a), we measure the cost of our HPTSA. Similar to prior work, our estimates are *not* meant to reflect the end-to-end cost of complete, real-world hacking tasks. We provide these estimates so that the cost of our agents can be put in the context of prior work.

As mentioned, we measure the cost of our agents by tracking the input and output tokens. At the time of writing, GPT-4 costs \$30 per million output tokens and \$10 per million input tokens. For open-source models, we used Fireworks API, costing \$3 per million tokens for Llama-3.5-405B and \$0.9 per million tokens for Qwen-2.5-72B.

As shown in Table 3, with GPT-4 the average cost for a run was \$4.39. With an overall success rate of 18%, the total cost would be \$24.4 per successful exploit for GPT-4. Compared to the one-day setting (Fang et al., 2024a), the overall cost is $2.8\times$ higher, while the per-run cost is comparable (\$4.39 vs \$3.52). Compared to open-source models, GPT-4 is $3.1\text{--}15\times$ higher per run. However, open-source models fail to resolve any tasks.

Using similar cost estimates for a cybersecurity

expert (\$50 per hour) as prior work, and an estimated time of 1.5 hours to explore a website, we arrive at a cost of \$75. Thus, our cost estimate for a human expert is higher, but not dramatically higher than using an AI agent.

However, we anticipate that costs of using AI agents will fall. For example, costs for GPT-4o were cut in half over six months and Claude-3.5-Haiku is $3\times$ cheaper than GPT-4o (per input token). If these trends in cost continue, we anticipate that a GPT-4o level agent will be $3\text{--}6\times$ cheaper than the cost today in the next 1-2 years. If such cost improvements do occur, AI agents will be substantially cheaper than a human expert.

8 Related Work

Cybersecurity and AI. Recent work in the intersection of cybersecurity and AI falls in three broad categories: human uplift, societal implications of AI, and AI agents.

In this work, we focus on AI agents and cybersecurity. The closest works to ours shows that ReAct-style AI agents can hack “capture-the-flag” toy websites and vulnerabilities when given a description of the vulnerability (Fang et al., 2024b,a). However, these agents fare poorly in the zero-day setting. In particular, it is challenging for agents to backtrack after exploring a dead end. We show in our work that teams of AI agents can autonomously exploit zero-day vulnerabilities. Our findings are of broader relevance to the community, as governmental agencies (US, 2025; UK, 2024), industrial labs (Weidinger et al., 2024; Anthropic, 2024), and other parties are interested in measuring cybersecurity capabilities of AI agents.

The human uplift setting focuses on using AI (typically LLMs) to aid humans in cybersecurity tasks. For example, recent work has shown that LLMs can aid humans in penetration testing and malware generation (Happe and Cito, 2023; Hilario et al., 2024). This work is especially important in the setting of “script kiddies” who deploy malware without special expertise. Based on this, and the work on AI agents, researchers have also speculated on societal implications of AI on cybersecurity (Lohn and Jackson, 2022; Handa et al., 2019).

AI agents. AI agents have becoming increasingly powerful and popular. Recent, highly capable AI agents are largely based on LLMs (Yao et al., 2022; Weng, 2023) and can now perform tasks as complex

as solving real-world GitHub issues (Yang et al., 2024b). There have been hundreds of papers on improving AI agents, ranging from prompting techniques (Wei et al., 2022; Yao et al., 2024), planning techniques (Shinn et al., 2024; Liu et al., 2023a), adding documents and memory (Nuxoll and Laird, 2012), domain-specific agents (He et al., 2024), and many more (Parisi et al., 2022). The field of multi-agent systems is particularly related to our work (Liu et al., 2023b; Chen et al., 2023; Zhang et al., 2023). However, to the best of our knowledge, our work is the first to introduce a real-world AI agent system based on hierarchical planning and task-specific agents.

Security of AI agents. A related area of work is the security of AI agents themselves (Greshake et al., 2023a; Kang et al., 2023; Zou et al., 2023; Zhan et al., 2023; Qi et al., 2023; Yang et al., 2023). Deployers of AI agents may want to limit the tasks that the AI agent can do (e.g., restricting the ability to perform cybersecurity attacks) and protect the agent against malicious attackers. Unfortunately, recent work has shown that it is simple to bypass protections in LLMs, such as by fine-tuning away protections (Zhan et al., 2023; Yang et al., 2023; Qi et al., 2023). AI agents can also be attacked via indirect prompt injection attacks (Greshake et al., 2023b; Yi et al., 2023; Zhan et al., 2024). This line of work is orthogonal to ours.

9 Conclusions

In this work, we show that teams of LLM agents can autonomously exploit zero-day vulnerabilities, resolving an open question posed by prior work (Fang et al., 2024a). Our findings suggest that cybersecurity, on both the offensive and defensive side, will increase in pace. Now, black-hat actors can use AI agents to hack websites. On the other hand, penetration testers can use AI agents to aid in more frequent penetration testing. It is unclear whether AI agents will aid cybersecurity offense or defense more and we hope that future work addresses this question. Beyond the immediate impact of our work, we hope that our work inspires frontier LLM providers to think carefully about their deployments.

10 Limitations, Ethical Considerations

Although our work shows substantial improvements in performance in the zero-day setting, much work remains to be done to fully understand the

implications of AI agents in cybersecurity. For example, we focused on web, open-source vulnerabilities, which may result in a biased sample of vulnerabilities. We hope that future work addresses this problem more thoroughly.

A major consideration when conducting research in potentially harmful uses of LLMs is that malicious actors can use the ideas for nefarious purposes. To help alleviate such issues, we have elected not to release our code or prompts publicly as OpenAI has requested that we keep our agents confidential. This is in line with prior work (Fang et al., 2024b,a) and best practice for cybersecurity (OWASP, 2024). Furthermore, we have disclosed our findings to OpenAI as part of their responsible disclosure program.

References

- Josh Achiam, Steven Adler, Sandhini Agarwal, Lama Ahmad, Ilge Akkaya, Florencia Leoni Aleman, Diogo Almeida, Janko Altenschmidt, Sam Altman, Shyamal Anadkat, et al. 2023. Gpt-4 technical report. *arXiv preprint arXiv:2303.08774*.
- Anthropic. 2024. [A new initiative for developing third-party model evaluations](#).
- Simon Bennetts. 2013. Owasp zed attack proxy. *AppSec USA*.
- Leyla Bilge and Tudor Dumitraş. 2012. Before we knew it: an empirical study of zero-day attacks in the real world. In *Proceedings of the 2012 ACM conference on Computer and communications security*, pages 833–844.
- Guangyao Chen, Siwei Dong, Yu Shu, Ge Zhang, Jaward Sesay, Börje F Karlsson, Jie Fu, and Yemin Shi. 2023. Autoagents: A framework for automatic agent generation. *arXiv preprint arXiv:2309.17288*.
- Abhimanyu Dubey, Abhinav Jauhri, Abhinav Pandey, Abhishek Kadian, Ahmad Al-Dahle, Aiesha Letman, Akhil Mathur, Alan Schelten, Amy Yang, Angela Fan, et al. 2024. The llama 3 herd of models. *arXiv preprint arXiv:2407.21783*.
- Richard Fang, Rohan Bindu, Akul Gupta, and Daniel Kang. 2024a. Llm agents can autonomously exploit one-day vulnerabilities. *arXiv preprint arXiv:2404.08144*.
- Richard Fang, Rohan Bindu, Akul Gupta, Qiusi Zhan, and Daniel Kang. 2024b. [Llm agents can autonomously hack websites](#). *Preprint*, arXiv:2402.06664.
- Ben SY Fung and Patrick PC Lee. 2011. A privacy-preserving defense mechanism against request forgery attacks. In *2011 IEEE 10th International Conference on Trust, Security and Privacy in Computing and Communications*, pages 45–52. IEEE.
- Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023a. More than you’ve asked for: A comprehensive analysis of novel prompt injection threats to application-integrated large language models. *arXiv e-prints*, pages arXiv–2302.
- Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023b. Not what you’ve signed up for: Compromising real-world llm-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*, pages 79–90.
- Anand Handa, Ashu Sharma, and Sandeep K Shukla. 2019. Machine learning in cybersecurity: A review. *Wiley Interdisciplinary Reviews: Data Mining and Knowledge Discovery*, 9(4):e1306.
- Andreas Happe and Jürgen Cito. 2023. Getting pwn’d by ai: Penetration testing with large language models. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 2082–2086.
- Hongliang He, Wenlin Yao, Kaixin Ma, Wenhao Yu, Yong Dai, Hongming Zhang, Zhenzhong Lan, and Dong Yu. 2024. Webvoyager: Building an end-to-end web agent with large multimodal models. *arXiv preprint arXiv:2401.13919*.
- Eric Hilario, Sami Azam, Jawahar Sundaram, Khwaja Imran Mohammed, and Bharanidharan Shanmugam. 2024. Generative ai for pentesting: the good, the bad, the ugly. *International Journal of Information Security*, pages 1–23.
- Daniel Kang, Xuechen Li, Ion Stoica, Carlos Guestrin, Matei Zaharia, and Tatsunori Hashimoto. 2023. Exploiting programmatic behavior of llms: Dual-use through standard security attacks. *arXiv preprint arXiv:2302.05733*.
- David Kennedy, Jim O’gorman, Devon Kearns, and Mati Aharoni. 2011. *Metasploit: the penetration tester’s guide*. No Starch Press.
- Edward Kost. 2023. [Critical microsoft exchange flaw: What is cve-2021-26855?](#)
- Hao Liu, Carmelo Sferrazza, and Pieter Abbeel. 2023a. Chain of hindsight aligns language models with feedback. *arXiv preprint arXiv:2302.02676*.
- Zijun Liu, Yanzhe Zhang, Peng Li, Yang Liu, and Diyi Yang. 2023b. Dynamic llm-agent network: An llm-agent collaboration framework with agent team optimization. *arXiv preprint arXiv:2310.02170*.
- Andrew Lohn and Krystal Jackson. 2022. Will ai make cyber swords or shields?

- Microsoft. 2024. Securing the cloud. <https://news.microsoft.com/stories/cloud-security/>. Accessed: 2024-05-19.
- Andrew M Nuxoll and John E Laird. 2012. Enhancing intelligent agents with episodic memory. *Cognitive Systems Research*, 17:34–48.
- OWASP. 2024. [Vulnerability disclosure cheat sheet](#). Online.
- Aaron Parisi, Yao Zhao, and Noah Fiedel. 2022. Talm: Tool augmented language models. *arXiv preprint arXiv:2205.12255*.
- Xiangyu Qi, Yi Zeng, Tinghao Xie, Pin-Yu Chen, Ruoxi Jia, Prateek Mittal, and Peter Henderson. 2023. Fine-tuning aligned language models compromises safety, even when users do not intend to! *arXiv preprint arXiv:2310.03693*.
- Emma Roth and Wes Davis. 2024. [Google i/o 2024: everything announced](#).
- Eko Budi Setiawan and Angga Setiyadi. 2018. Web vulnerability analysis and implementation. In *IOP conference series: materials science and engineering*, volume 407, page 012081. IOP Publishing.
- Noah Shinn, Federico Cassano, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. 2024. Reflexion: Language agents with verbal reinforcement learning. *Advances in Neural Information Processing Systems*, 36.
- Project sqlmap. 2024. [sqlmap: Automatic sql injection and database takeover tool](#).
- AISI UK. 2024. [Ai safety institute approach to evaluations](#).
- AISI US. 2025. [Technical blog: Strengthening ai agent hijacking evaluations](#).
- Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Fei Xia, Ed Chi, Quoc V Le, Denny Zhou, et al. 2022. Chain-of-thought prompting elicits reasoning in large language models. *Advances in neural information processing systems*, 35:24824–24837.
- Laura Weidinger, Joslyn Barnhart, Jenny Brennan, Christina Butterfield, Susie Young, Will Hawkins, Lisa Anne Hendricks, Ramona Comanescu, Oscar Chang, Mikel Rodriguez, et al. 2024. Holistic safety and responsibility evaluations of advanced ai models. *arXiv preprint arXiv:2404.14068*.
- Lilian Weng. 2023. [Llm-powered autonomous agents](#). lilianweng.github.io.
- An Yang, Baosong Yang, Beichen Zhang, Binyuan Hui, Bo Zheng, Bowen Yu, Chengyuan Li, Dayiheng Liu, Fei Huang, Haoran Wei, et al. 2024a. Qwen2. 5 technical report. *arXiv preprint arXiv:2412.15115*.
- John Yang, Carlos E. Jimenez, Alexander Wettig, Kilian Lieret, Shunyu Yao, Karthik Narasimhan, and Ofir Press. 2024b. Swe-agent: Agent computer interfaces enable software engineering language models.
- Xianjun Yang, Xiao Wang, Qi Zhang, Linda Petzold, William Yang Wang, Xun Zhao, and Dahua Lin. 2023. Shadow alignment: The ease of subverting safely-aligned language models. *arXiv preprint arXiv:2310.02949*.
- Shunyu Yao, Dian Yu, Jeffrey Zhao, Izhak Shafran, Tom Griffiths, Yuan Cao, and Karthik Narasimhan. 2024. Tree of thoughts: Deliberate problem solving with large language models. *Advances in Neural Information Processing Systems*, 36.
- Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. 2022. ReAct: Synergizing reasoning and acting in language models. *arXiv preprint arXiv:2210.03629*.
- Jingwei Yi, Yueqi Xie, Bin Zhu, Keegan Hines, Emre Kiciman, Guangzhong Sun, Xing Xie, and Fangzhao Wu. 2023. Benchmarking and defending against indirect prompt injection attacks on large language models. *arXiv preprint arXiv:2312.14197*.
- Qiusi Zhan, Richard Fang, Rohan Bindu, Akul Gupta, Tatsunori Hashimoto, and Daniel Kang. 2023. Removing rlhf protections in gpt-4 via fine-tuning. *arXiv preprint arXiv:2311.05553*.
- Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. 2024. Injecagent: Benchmarking indirect prompt injections in tool-integrated large language model agents. *arXiv preprint arXiv:2403.02691*.
- Andy K Zhang, Neil Perry, Riya Dulepet, Joey Ji, Justin W Lin, Eliot Jones, Celeste Menders, Gashon Hussein, Samantha Liu, Donovan Jasper, et al. 2024. Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. *arXiv preprint arXiv:2408.08926*.
- Hongxin Zhang, Weihua Du, Jiaming Shan, Qinzhong Zhou, Yilun Du, Joshua B Tenenbaum, Tianmin Shu, and Chuang Gan. 2023. Building cooperative embodied agents modularly with large language models. *arXiv preprint arXiv:2307.02485*.
- Andy Zou, Zifan Wang, J Zico Kolter, and Matt Fredrikson. 2023. Universal and transferable adversarial attacks on aligned language models. *arXiv preprint arXiv:2307.15043*.